

MODULE 3

Access Control

Network Defense | Cisco Networking Academy

Prepared by: Kudzaishe Majeza

Cisco Networking Academy | 2026

Topics Covered:

- 3.1 • Access Control Concepts
- 3.2 • AAA Usage and Operation
- 3.3 • AAA Servers — RADIUS and TACACS+
- 3.4 • Multi-factor Authentication (MFA)
- 3.5 • Least Privilege and Need to Know
- 3.6 • Implementing Access Control

3.1 Access Control Concepts

The rules and policies that determine who can access which resources in a system

What is Access Control?

- Access control is the process of granting or denying requests to use resources, systems, or data
- It ensures only authorised users and devices can access protected resources
- Access control directly supports the CIA Triad — Confidentiality, Integrity, and Availability
- Confidentiality: prevents unauthorised reading of sensitive data
- Integrity: prevents unauthorised modification of data or configurations
- Availability: ensures authorised users can reliably access what they need

Types of Access Control

- Physical Access Control — doors, badges, biometrics, and security guards protecting physical spaces
- Logical Access Control — software controls such as usernames, passwords, ACLs, and encryption
- Administrative Access Control — policies, procedures, and training that define how access is managed
- All three types must work together — no single layer is sufficient on its own

3.2 AAA Usage and Operation

Authentication, Authorization, and Accounting form the core framework for controlling access

Authentication — Who Are You?

- Authentication verifies the identity of a user, device, or system before granting access
- Something you know — password, PIN, or passphrase
- Something you have — smart card, security token, or OTP device
- Something you are — biometrics such as fingerprints, iris scan, or facial recognition
- Using more than one factor (MFA) makes authentication significantly stronger
- Failed authentication attempts must always be logged and monitored

Authorization and Accounting

- Authorization defines what an authenticated user is permitted to do on the system
- Permissions and access rights are granted based on identity and role
- Authorization always follows authentication — identity must be proven first
- Accounting tracks and records all user actions — who accessed what, when, and for how long
- Audit logs are essential for security investigations and compliance reporting

3.3 AAA Servers — RADIUS and TACACS+

Centralised AAA servers manage authentication consistently across all network devices

RADIUS — Remote Authentication Dial-In User Service

- Centralised AAA protocol for users connecting to a network (Wi-Fi, VPN, 802.1X)
- Combines authentication and authorization into a single response packet
- Uses UDP ports 1812 (authentication) and 1813 (accounting)
- Encrypts only the password in the request — other attributes sent in cleartext
- Widely supported across Cisco routers, switches, and wireless controllers
- Best suited for managing end-user network access

TACACS+ — Terminal Access Controller Access-Control System Plus

- Cisco-developed protocol that separates authentication, authorization, and accounting into three distinct processes
- Encrypts the entire body of every packet — stronger confidentiality than RADIUS
- Uses TCP port 49 for reliable, connection-oriented communication
- Preferred for managing access to network infrastructure devices such as routers and switches
- Key difference: RADIUS for user network access; TACACS+ for device administration

3.4 Multi-factor Authentication (MFA)

Requiring more than one factor makes accounts dramatically harder to compromise

Why MFA Is Essential

- Passwords alone are easily stolen through phishing, data breaches, or brute force attacks
- MFA requires two or more independent verification factors from different categories
- Even if one factor is compromised, the attacker cannot gain access without the second
- MFA reduces the risk of account takeover by over 99% (Microsoft research)
- Mandated by compliance frameworks including PCI-DSS, HIPAA, and NIST 800-63
- Must be enabled on all critical systems, especially administrative and privileged accounts

Common MFA Implementations

- Authenticator Apps — Time-based OTPs generated every 30 seconds (Google / Microsoft Authenticator)
- Hardware Tokens — Physical devices that generate OTPs or use cryptographic challenge-response (YubiKey, RSA SecurID)
- SMS / Email OTP — One-time code sent to a registered device; convenient but vulnerable to SIM-swap attacks
- Biometrics — Fingerprint, facial recognition, or iris scan used alongside a password or PIN
- Push Notifications — Approve login requests on a trusted registered device (Cisco Duo)

3.5 Least Privilege and Need to Know

Limiting access to only what is necessary is one of the most effective security controls

Principle of Least Privilege

- Users, programs, and systems get only the minimum access rights needed for their function
- Limits the damage caused by a compromised account, malware infection, or insider threat
- Admin and privileged accounts must only be used for tasks that require elevated permissions
- Privilege creep occurs when users accumulate permissions over time without regular review
- Periodic access reviews and automatic privilege expiration should be enforced
- Applies equally to users, service accounts, applications, and network devices

Need to Know and Separation of Duties

- Need to Know: users should only access information directly relevant to their specific role
- Even a user with the correct clearance level must not access data outside their operational need
- Separation of Duties ensures no single person can complete a high-risk transaction alone
- SoD prevents fraud, errors, and insider abuse by requiring multiple people for sensitive operations
- Data classification systems help enforce Need to Know consistently across all departments

3.6 Implementing Access Control

Access control models define how permissions are assigned and enforced across a system

Access Control Models

- DAC (Discretionary) — Resource owner decides who can access it. Flexible but hard to enforce at scale
- MAC (Mandatory) — System enforces access based on security labels and clearance levels. Used in government and military
- RBAC (Role-Based) — Permissions assigned to job roles, not individuals. Most common in enterprise environments
- ABAC (Attribute-Based) — Access decisions based on user, resource, and environment attributes. Highly flexible
- Rule-Based — Fixed administrator-defined rules governing access (e.g. ACLs on routers and firewalls)

Access Control Lists (ACLs)

- ACLs are ordered lists of permit and deny rules applied to network traffic or file system resources
- Standard ACLs filter traffic based on source IP address only
- Extended ACLs filter by source/destination IP, protocol, and port numbers — far more granular
- ACLs are processed top-down; the first matching rule is applied and the rest are skipped
- An implicit deny-all rule at the end blocks all traffic not explicitly permitted
- Extended ACLs should be placed as close to the source of traffic as possible

3 Summary — Access Control

Key concepts from this module

Concepts

- Access control ensures only authorised users can access protected resources
- Three types: Physical, Logical, Administrative — all must work together
- AAA is the core access control framework for all networks
- Authentication: something you know, have, or are
- Authorization follows authentication and defines what you are allowed to do
- Accounting logs user activity for audit trails and compliance
- RADIUS: centralised network access AAA using UDP (combines auth + authz)
- TACACS+: device administration AAA using TCP (separates all three, full encryption)

Controls

- MFA reduces account takeover risk by over 99% — enable it everywhere
- MFA factors: something you know + something you have + something you are
- Least Privilege: grant only the minimum access necessary for the job
- Privilege creep must be prevented through regular access reviews
- Need to Know: access only the data relevant to your specific role
- Separation of Duties: require multiple people for sensitive operations
- DAC / MAC / RBAC / ABAC — know the four core access control models
- ACLs: ordered permit/deny rules; implicit deny-all at the bottom